MID-STATE TECHNICAL COLLEGE · IT PROGRAMS

Blocking Known Threats Using Security Profiles

Unit 9 · Information Security 2 (10-151-111)

MID-STATE TECHNICAL COLLEGE

Learning Outcomes

By the end of this unit, you will be able to:



Describe Content-ID and Security Profiles

Explain where profiles run in the flow logic and what each of the seven types inspects.



Use IPS and antivirus profiles to block threats

Configure Vulnerability Protection and Antivirus profiles and tune them with exceptions.



Sinkhole command-and-control traffic

Build an Anti-Spyware profile that sinkholes malicious domains from an External Dynamic List.



Implement a data loss prevention strategy

Configure File Blocking and Data Filtering profiles for files and messages.



Apply, troubleshoot, and defend

Attach Security Profile Groups, read the logs, and configure DoS protection.

LESSON 1

Content-ID and Security Profiles

Allowed Is Not the Same as Safe

- A Security policy rule decides **whether** traffic is allowed. It does not decide whether that traffic is **safe**.
- **Content-ID** is a single-pass engine that inspects allowed traffic for exploits, viruses, spyware, malicious URLs, and restricted files or data.
- **Security Profiles** attach only to rules with an `allow` action. A deny rule has already dropped the traffic.
- Profiles apply to every packet for the **life of the session**, not just the first packet.



Allow, but inspect

Web browsing may be a legitimate business application. A user can still download malware over it, and an infected host can still beacon out through it.

Where Content-ID Runs in the Flow Logic

A simplified view of the packet path through a Palo Alto Networks firewall:

Stage	What happens	Covered in
Session setup	Zone and DoS Protection, forwarding lookup, Security policy check	Units 5–6, Lesson 5
App-ID	Identifies the application inside the session	Unit 8
Decryption	Decrypts the session when a Decryption policy matches	Unit 13
Content-ID	Security Profiles inspect the content and enforce their actions	This unit

Content-ID cannot inspect encrypted traffic. Without a Decryption policy, TLS sessions pass through the profiles unseen.

The Seven Security Profile Types

Profile	Detects or controls	Logs to
Antivirus	Infected files: viruses, worms, trojans	Threat
Anti-Spyware	Spyware and command-and-control traffic	Threat
Vulnerability Protection	Exploits of known software flaws (IPS)	Threat
File Blocking	File types by application and direction	Data Filtering
Data Filtering	Sensitive data patterns such as SSNs	Data Filtering
Advanced URL Filtering	Web access by URL category (Unit 10)	URL Filtering
WildFire Analysis	Unknown files sent for analysis (Unit 11)	WildFire

A Security Profile Group bundles one profile of each type so it can be attached in a single step.

Profile Actions

Let it through

- `allow` permits the traffic without logging
- `alert` permits the traffic and writes a log entry
- `default` uses the action Palo Alto Networks assigned to each signature

Stop it

- `drop` silently discards the traffic and logs it
- `reset-client`, `reset-server`, `reset-both` send a TCP reset, or drop UDP
- `block-ip` blocks a source for a set number of seconds; `sinkhole` forges a DNS answer

Predefined profiles are read-only: clone the default or strict profile and edit the clone, or add a new empty profile. Lab 8 uses the clone approach.

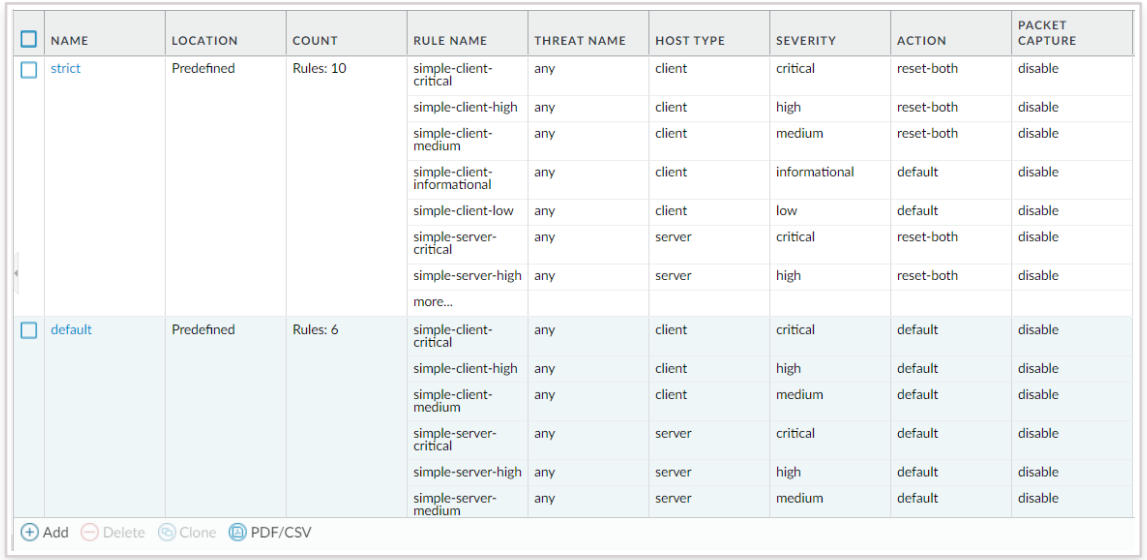
LESSON 2

Intrusion Prevention and Antivirus



Vulnerability Protection: default vs. strict

- Stops attempts to exploit flaws, such as **buffer overflows** and **illegal code execution**.
- `default` applies each signature's default action to critical, high, and medium events. Use it for proof-of-concept deployments.
- `strict` applies `reset-both` to critical, high, and medium events. This is the recommended starting point.

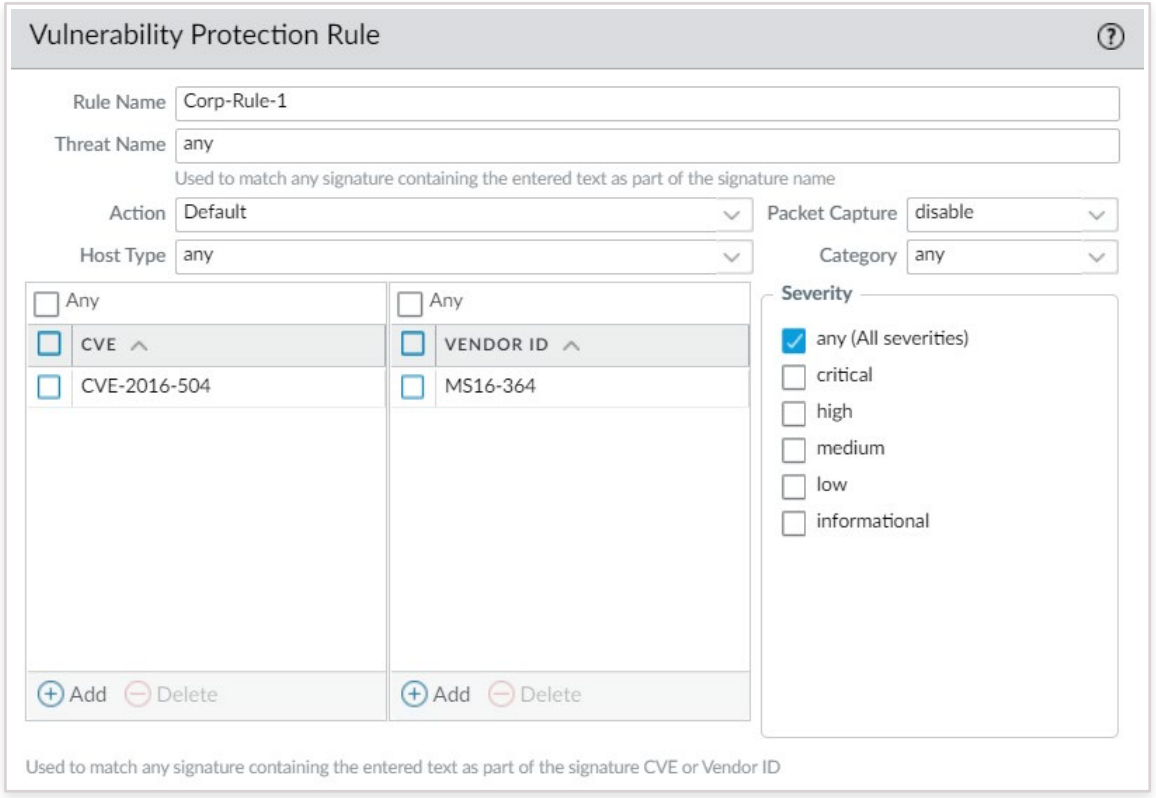


NAME	LOCATION	COUNT	RULE NAME	THREAT NAME	HOST TYPE	SEVERITY	ACTION	PACKET CAPTURE
strict	Predefined	Rules: 10	simple-client-critical	any	client	critical	reset-both	disable
			simple-client-high	any	client	high	reset-both	disable
			simple-client-medium	any	client	medium	reset-both	disable
			simple-client-informational	any	client	informational	default	disable
			simple-client-low	any	client	low	default	disable
			simple-server-critical	any	server	critical	reset-both	disable
			simple-server-high	any	server	high	reset-both	disable
			more...					
default	Predefined	Rules: 6	simple-client-critical	any	client	critical	default	disable
			simple-client-high	any	client	high	default	disable
			simple-client-medium	any	client	medium	default	disable
			simple-server-critical	any	server	critical	default	disable
			simple-server-high	any	server	high	default	disable
			simple-server-medium	any	server	medium	default	disable

Add Delete Clone PDF/CSV

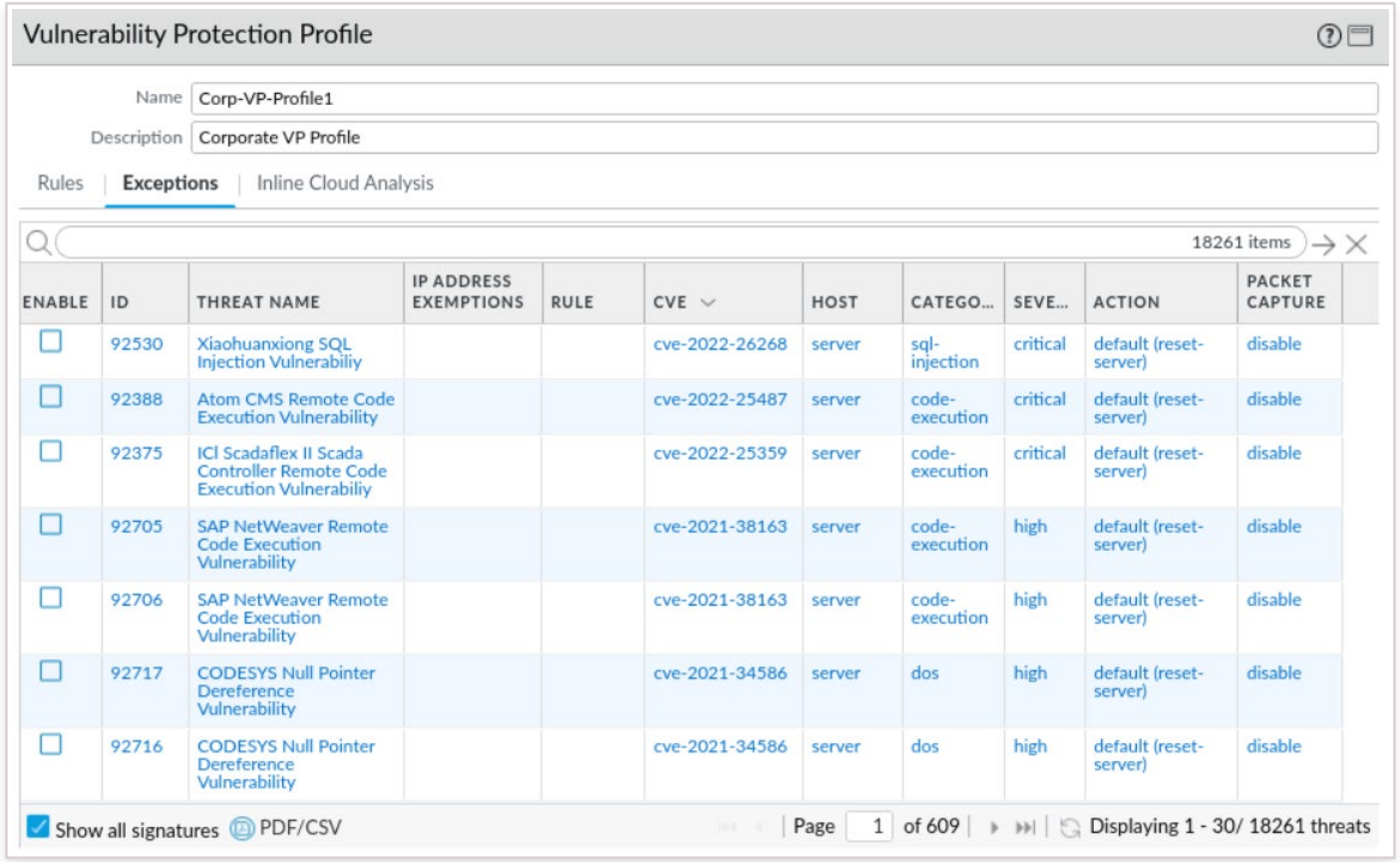
Objects > Security Profiles > Vulnerability Protection

Building Vulnerability Protection Rules



- **Threat Name**: `any`, or a string that matches part of a signature name
- **Host Type**: match threats against the client, the server, or any host
- **Category and Severity**: narrow the rule to specific kinds and levels of threats
- **CVE / Vendor ID**: match only signatures tied to a specific advisory
- **Packet Capture**: save the packets that triggered the match

Exceptions and Inline Cloud Analysis



SECURITY FOCUS

Handle a false positive with an exception for that one threat ID, scoped to specific IP addresses where possible.

Why it matters: Downgrading the whole profile to alert turns off blocking for every signature to fix one.

Antivirus Profiles

Stream-based scanning starts on the first packet. Each protocol decoder has its own default action:

Decoder	Default action	Why
FTP, HTTP, SMB	reset-both	Interactive transfers can be stopped cleanly mid-stream
IMAP, POP3	alert	Store-and-forward mail resends until delivered; clean it at the mail server
SMTP	alert	The firewall sends a 541 response so the sending server stops retrying

Three action columns: Action (daily signatures), WildFire Action (WildFire signatures), and WildFire Inline ML Action (real-time verdicts on PE, ELF, and PowerShell files).

Antivirus Exceptions

- **Signature Exceptions**: add the threat ID from the Threat log to stop acting on a known-benign match.
- **Application Exceptions**: change the action for one application without changing it for everything else.
- **Inline ML File Exceptions**: exclude a specific file by partial hash and file name.
- Turn on **Packet Capture** to keep evidence of what triggered the match.



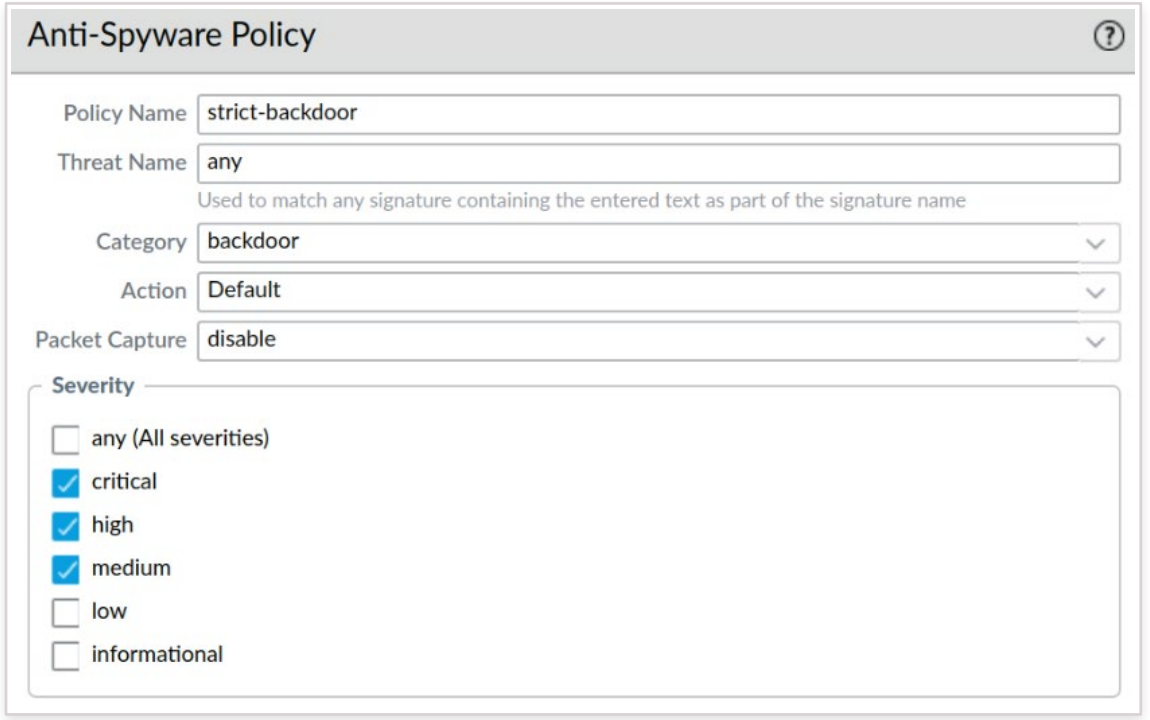
LESSON 3

Anti-Spyware and DNS Sinkholing



Anti-Spyware Profiles

- Detects spyware downloads and **command-and-control (C2)** traffic leaving infected hosts.
- Ships `default` and `strict` predefined profiles, just like Vulnerability Protection.
- Rules match threat name, category, and severity, and can include `block-ip` and packet capture.
- **DNS over HTTPS (DoH)**: from PAN-OS 11.0, the firewall can decrypt DoH requests and apply DNS policy to them.



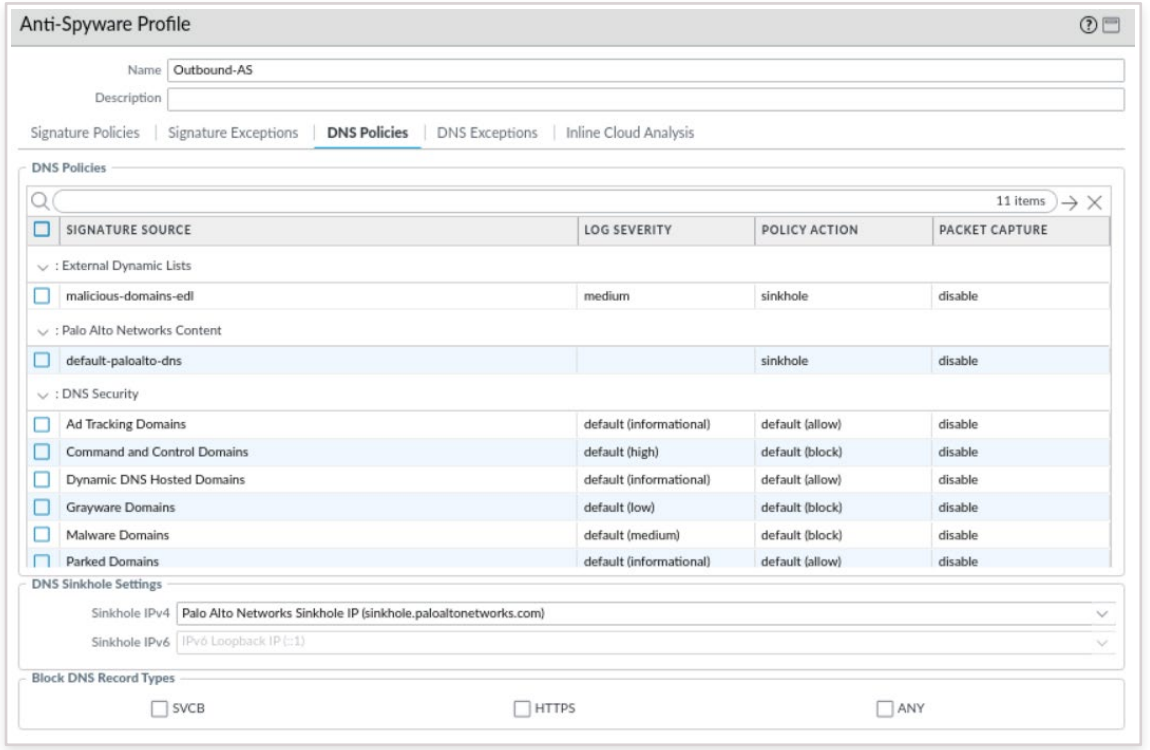
How a DNS Sinkhole Works

Step	What happens
1	An infected host asks the local DNS server to resolve a malicious domain
2	The local DNS server forwards the query toward an external resolver, through the firewall
3	The firewall matches the domain against a DNS signature or an External Dynamic List
4	Instead of forwarding the query, the firewall answers with the sinkhole address
5	The local DNS server passes the forged answer back to the infected host
6	The host tries to connect to the sinkhole address, and the firewall logs the attempt

Put the sinkhole address in a different zone from the DNS clients so the connection attempt crosses the firewall and is logged.

Sinkholing an External Dynamic List

- **External Dynamic List (EDL)**: a domain list the firewall pulls from a URL on a schedule.
- On the **DNS Policies** tab, set the EDL's policy action to `sinkhole`.
- Use the Palo Alto Networks sinkhole FQDN, or your own address in a separate zone.
- **DNS Exceptions**: allow-list approved domains or exclude specific DNS threat IDs.



Finding the Infected Host

- A `sinkhole` entry in the Threat log means a malicious lookup was intercepted.
- If the firewall sits north of your internal DNS server, the Threat log shows the **DNS server** as the source.
- Filter the **Traffic log** on the sinkhole IP address to find the hosts trying to connect to it.
- Check these logs daily, or schedule a report.



SECURITY FOCUS

Every host that connects to the sinkhole address is very likely compromised and is actively trying to reach its operator.

Why it matters: A sinkhole blocks one domain. The malware is still on the host until someone removes it.

LESSON 4

Data Loss Prevention



Two Profiles, One DLP Strategy

File Blocking

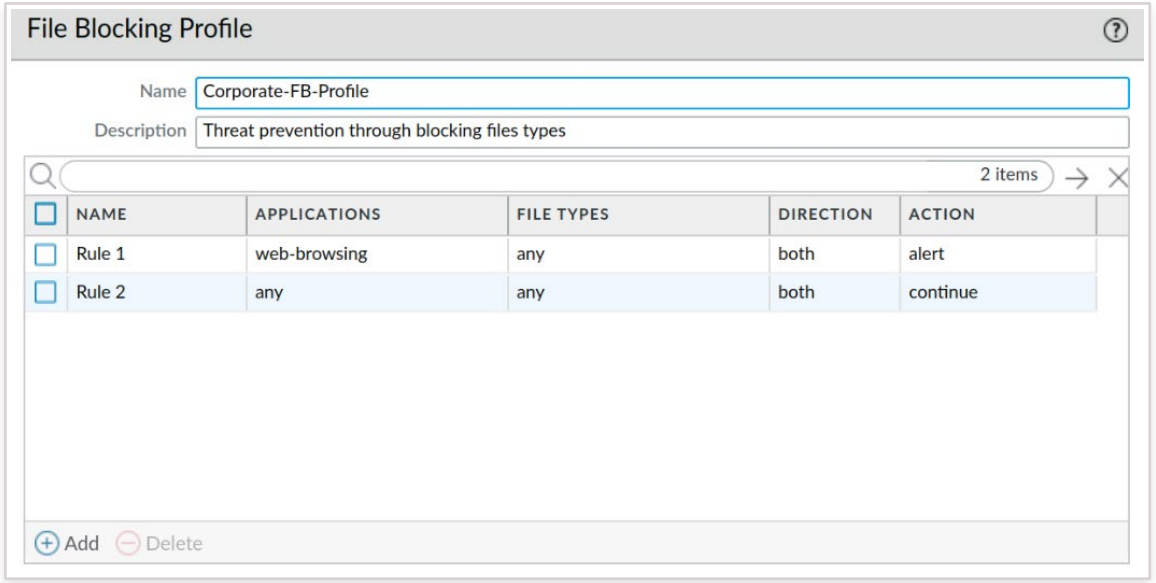
- Controls **what kind** of file moves: by application, file type, and direction
- Identifies type by content as well as extension, including files inside ZIP archives
- Predefined `basic file blocking` and `strict file blocking` profiles

Data Filtering

- Controls **what's inside** files and messages: SSNs, card numbers, keywords
- Alert and block **thresholds** count pattern matches before acting
- Supports HIPAA, GDPR, and GLBA compliance with 20+ predefined patterns

Both directions: DLP stops malicious files coming in and sensitive data going out. Both profiles log to Monitor > Logs > Data Filtering.

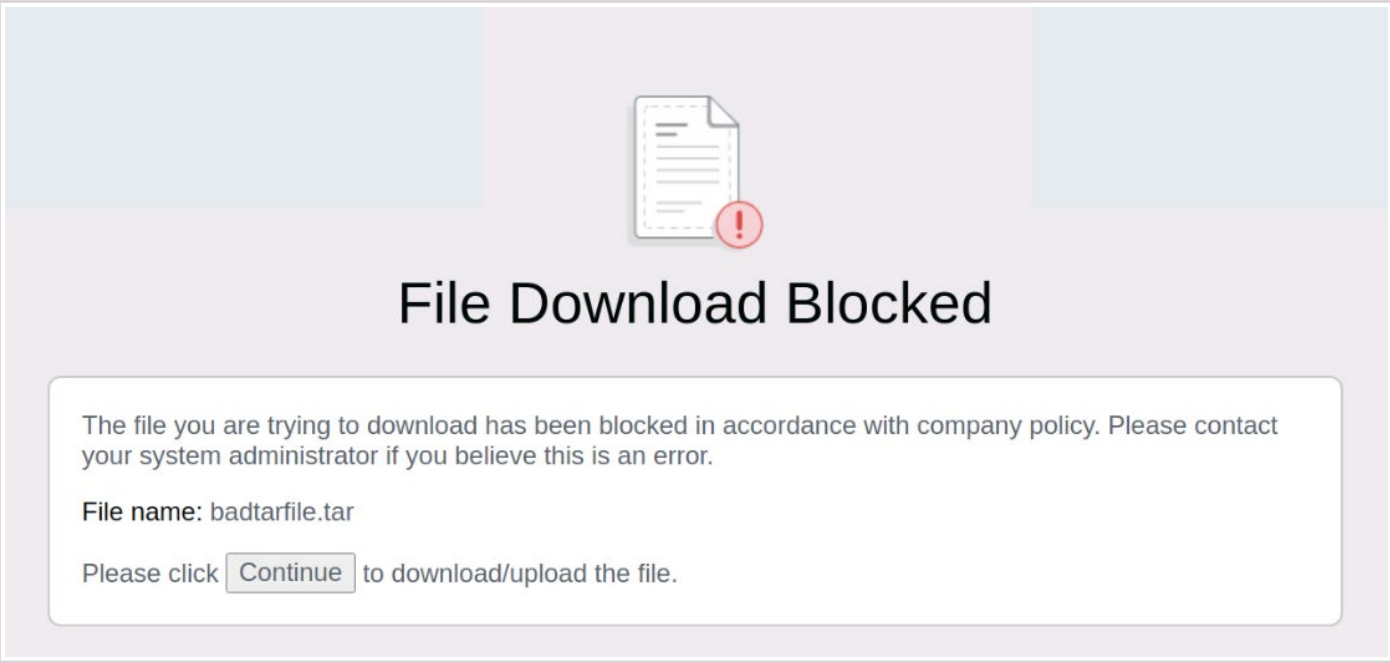
File Blocking Rules and Actions



- `alert`: allows the transfer and logs it
- `block`: stops the transfer, logs it, and shows a block page
- `continue`: lets the user decide on a response page. Works with `web-browsing` only
- **Precedence**: continue, then block, then alert. Rule order does not matter

A blocked EXE inside a ZIP archive blocks the entire ZIP.

What the User Sees



Response pages

Block shows File Transfer Blocked. Continue shows this page with a Continue button, which defeats drive-by downloads the user never requested.

Multi-Level Encoding

One ordinary Word document can already be several layers deep:

```
Level 4  HTTP chunked transfer encoding
Level 3  gzip
Level 2  .zip archive
Level 1  .docx (XML and binaries)
```

- The firewall decodes up to **four levels**: base64, gzip, chunked HTTP, pkzip, qpencode, and uuencode.
- Add a File Blocking rule for `Multi-Level-Encoding` with the `block` action to stop anything nested more deeply.

Data Patterns

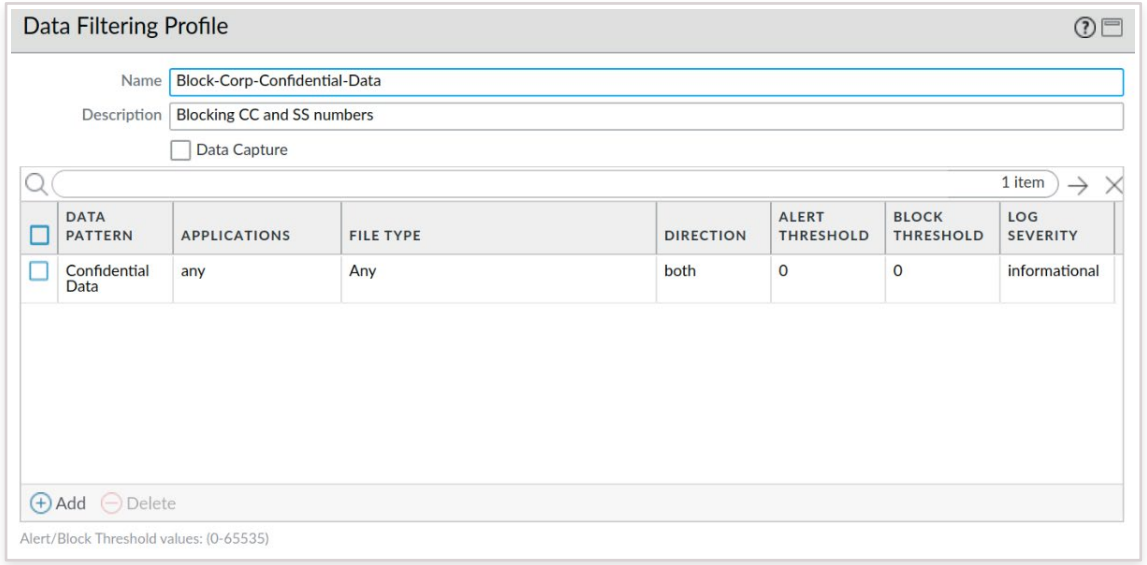
A Data Filtering profile scans for the patterns defined in Objects > Custom Objects > Data Patterns:

Pattern type	Matches	Example
Predefined	Built-in, checksum-validated formats	SSNs, credit card numbers
Regular Expression	Custom formats you define	Employee IDs, project code names
File Properties	Document metadata	Title, author, classification tag

Predefined patterns use checksum validation to cut false positives. Lab 8 combines the SSN patterns with and without dashes into one data pattern, US-SSNs.

Building a Data Filtering Profile

- Each rule sets the **data pattern**, applications, file types, and direction.
- **Alert threshold**: the number of matches that writes a log entry.
- **Block threshold**: the number of matches that stops the transfer.
- **Data Capture**: saves a copy of the blocked data for investigation and evidence.



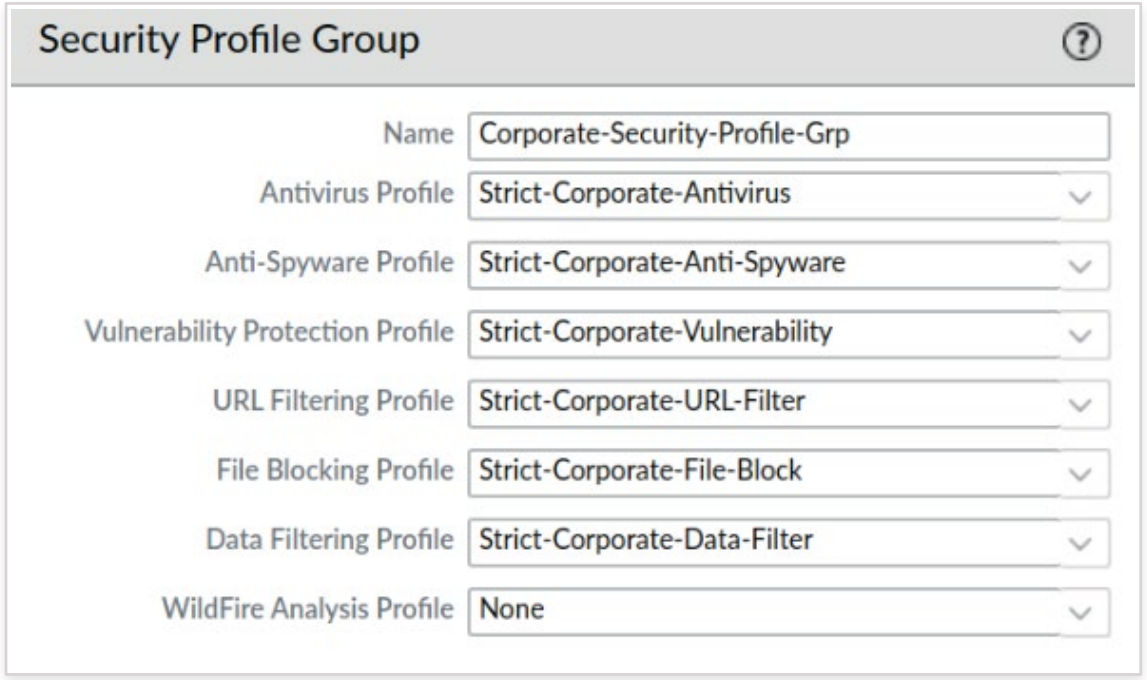
LESSON 5

Apply, Monitor, and Defend

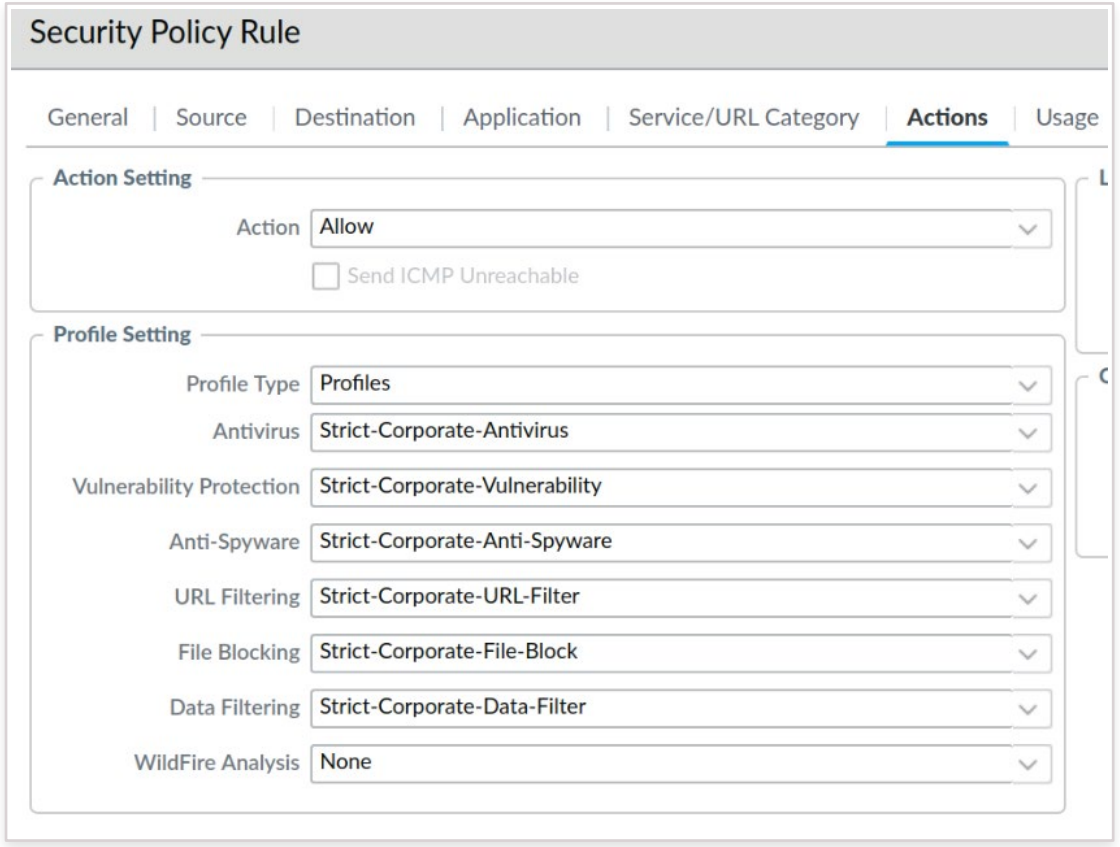


Security Profile Groups

- A **Security Profile Group** holds one profile of each type and attaches in one step.
- Tighten one profile and every rule that uses the group gets the change.
- Created under **Objects > Security Profile Groups**.
- Lab 8 leaves URL Filtering and WildFire Analysis set to `none`.



Attaching Profiles to Security Rules



- On the rule's **Actions** tab, set **Profile Type** to `Profiles` or `Group`.
- Attach profiles to **every** allow rule. One missed rule is an uninspected path.
- In **Policies > Security**, hover over a profile icon to confirm what is attached.
- Nothing takes effect until you **commit**.

Which Log Tells You What

Log	Records	Source means
Threat	Antivirus, Anti-Spyware, and Vulnerability detections, with threat ID	The session initiator
Data Filtering	File Blocking and Data Filtering events, with file name and type	The system that sent the file
Traffic	Every session, including attempts to reach the sinkhole address	The session initiator

Watch the Source column: For a download, the Data Filtering log lists the web server as the source. The Traffic log lists your user as the source of the same session.

Troubleshooting Security Profiles

Symptom	Check
Nothing is blocked	The rule allows the traffic, a profile or group is attached, and the change is committed
Encrypted traffic passes	Content-ID cannot see inside TLS without a Decryption policy (Unit 13)
Legitimate traffic is blocked	Find the threat ID or file type in the log, then add a targeted exception
DLP does not trigger	The match count reaches the block threshold, the pattern fits the real format, the direction is right
You need proof	Turn on packet capture or Data Capture, reproduce the problem, and review the evidence

Fix the configuration, not the symptom. Disabling a profile to make an error go away removes the protection with it.

Recognizing a DoS Attack

- **SYN flood**: a flood of half-open TCP connections that exhausts the session table.
- **UDP and ICMP floods**: high-rate packets that consume bandwidth and processing.
- **Session spikes**: new connections per second jump far above the normal baseline.
- **Distributed DoS (DDoS)**: the same floods from many sources at once, so blocking one IP does not help.



Not a Security Profile

DoS defenses run at session setup, before the Security policy lookup. Content-ID never sees the flood.

Zone Protection and DoS Protection Policy

Zone Protection profile

- Attached to a zone under **Network > Zones**
- Flood, reconnaissance, and packet-based attack protection
- The first line of defense on internet-facing zones

DoS Protection policy

- Rules under **Policies > DoS Protection** match zone, address, and service
- Uses a DoS Protection profile from **Objects > Security Profiles**
- **Aggregate** limits a group of hosts; **classified** limits per IP

Threshold	At this connection rate, the firewall…
Alarm Rate	Writes an alarm to the log
Activate Rate	Starts dropping new connections (Random Early Drop, or SYN Cookies for SYN floods)

Max Rate drops all new connections. Set every threshold from a measured baseline, or you will block legitimate traffic.

Security Focus: Every Allow Rule Is a Promise

SECURITY FOCUS

An allow rule without Security Profiles trusts everything inside the traffic it permits: exploits, malware downloads, C2 beacons, and outbound customer data. Attach a Security Profile Group to every allow rule, start from the strict profiles, and tune with exceptions instead of downgrades.

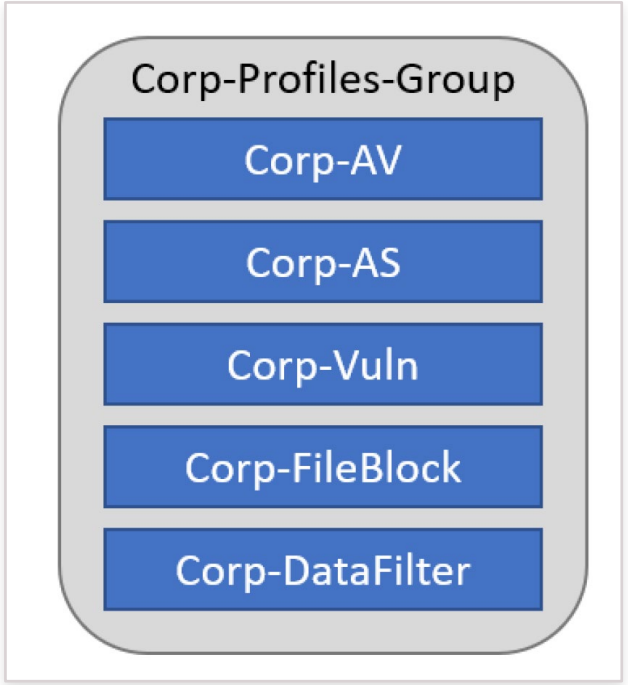
Why it matters: The breach does not come through the traffic you denied. It comes through the traffic you allowed and never inspected.

In Zero Trust, no zone is fully trusted, so even internal-to-internal allow rules get profiles.

Hands-On Lab: NETLAB+ Lab 8

NETLAB+ · PAN-OS 11.0 Essentials · Lab 8: Blocking Known Threats Using Security Profiles

- Load and commit the `edu-210-11.0a-08.xml` baseline, then generate traffic with no profiles
- Clone the predefined profiles to create Corp-AV, Corp-Vuln, Corp-FileBlock, and Corp-AS
- Build the US-SSNs data pattern and Corp-DataFilter, with alert at 1 match and block at 3
- Sinkhole malicious-domains-edl, build Corp-Profiles-Group, and attach it to all six allow rules
- Replay the attacks and confirm the blocks in the browser, in dig, and in the logs



Also due: the Unit 9 Quiz. Always check Blackboard for due dates.

Check Your Understanding

#	Question
1	Which anti-spyware feature lets an administrator quickly identify a potentially infected host on the network?
2	True or false: a Security Profile is evaluated only if its Security policy rule matches the traffic and the rule action is allow.
3	Traffic matches an allow rule, but the attached File Blocking profile blocks it. Which two logs record the event?

Discuss with a neighbor before we reveal the answers.

Key Takeaways

- Security Profiles inspect allowed traffic. A rule without them only decides access.
- Start from strict and handle false positives with targeted exceptions, never downgrades.
- A DNS sinkhole blocks C2 lookups and shows you which host is infected.
- File Blocking controls file types; Data Filtering controls what is inside them.
- Attach a Security Profile Group to every allow rule, and stop floods at the zone with DoS defenses.

MID-STATE TECHNICAL COLLEGE · IT PROGRAMS

Questions?

Unit 9 · Blocking Known Threats Using Security Profiles

MID-STATE TECHNICAL COLLEGE